

[doc. web n. 9978342]
Provision of December 7, 2023
Register of provisions
n. 587 of December 7, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia, and Attorney Guido Scorza, members, and
Secretary General Cons. Fabio Mattei;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing
Directive 95/46/EC (hereinafter "Code");

HAVING REGARD TO Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers assigned to the Guarantor for the
protection of personal data, approved by
resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web
n.9107633 (hereinafter "Guarantor Regulation No.
1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary
General pursuant to Article 15 of the Guarantor's
Regulation No. 1/2000 on the organization and
functioning of the office of the Guarantor for the
protection of personal data, on www.gpdp.it, doc.
web n.1098801;

Reporting by Prof. Ginevra Cerrina Feroni;

PREMISED

1. The complaint and the investigative activity
The Territorial Social Health Company of North Milan
(hereinafter Company) on February 25, 2022,
notified, pursuant to Article 33 of the Regulation,
a personal data breach in which it was stated that "Mr. (Y) on January 29, 2022, went to take a swab

to verify his COVID status. The result could have been verified from February 3 of this year. On January 31, 2022, Mrs. (X) (who, from investigations carried out by this office, was found to be the spouse of Mr. (Y) as well as an employee of this ASST North Milan) without any delegation managed to receive from a company healthcare operator a printout of the report."

With a note dated May 23, 2022, the Office requested information from the aforementioned Company regarding compliance with the principles of personal data protection in the processing carried out through the company health dossier, in relation to the facts above represented.

On March 16, 2023, Mr. (Y) sent a complaint regarding the facts subject to the aforementioned notification of breach, to which the Office again requested information from the aforementioned Company with the note dated May 9, 2023 (prot. n. 74006). In the response provided by the Company with a note dated May 12, 2023, the statements made by the social healthcare operator (OSS) and the nurse (Mrs. X) regarding the facts subject to the complaint were reported, and the training activities carried out by the Company were indicated, representing, in particular, that: "The company information systems have been

fairly stable in their administrative functions until March 2020, when due to the Covid emergency, to prioritize the care needs of patients in light of a staffing that was also experiencing availability issues, it was decided to provide greater access to healthcare professionals (doctors and nurses) as they were assigned to various departments and services on a daily basis, often without notice, incompatible with proper management of user accounts. As the pandemic waned, the medical component was gradually restored to the correct configurations while the nursing component, due to other factors that led to turnover above the average and to still frequently sudden use of cross replacements between departments, is still configured with access to all services";

"It is necessary, for organizational needs, such as for example the sudden absence of nursing staff and/or OSS, due to illness, accidents, etc., or due to increased flow of patients to be admitted to certain Departments, coming from the Emergency Room, that personnel from other operational Units be assigned. This temporary organizational compensation is necessary to avoid the interruption of public service."

Subsequently, with a note dated June 9, 2023, this Office requested further informational elements which were provided by the aforementioned Company with a note dated July 6, 2023, in which it was represented, in particular, that:

"As for the nurses and hospital doctors during the pandemic period, the same solution was implemented, namely allowing access to data from all hospital departments and the emergency room without specific limitations" in relation to the "continuous and unprogrammable rotation and movement from one department to another in "based on the needs of the moment";

"At the end of the pandemic period, for the first group considered (hospital nurses and doctors), the situation remained almost unchanged, and a process for reviewing access and profiles is being prepared; whereas for the second group (outpatient doctors), access to emergency room data has been eliminated, and they have been included in 'working groups' regarding access to department data";

"a general review process of corporate profiles is underway, which will not simply lead to their modification but to the creation of new profiles tailored to the actual access rights distinct for 'working groups'. This solution has the emergency room user accounts as a pilot project, with the aim of subsequently extending this method to all departments. In the meantime, all non-operational user accounts have been eliminated because the assignee no longer works for ASST Nord Milano or because access to them had not been executed for a considerable period of time";

"The professional nurse (X), with duties related to nursing jobs in the Rehabilitation department, is responsible for patient assistance (previously also for green pass checks), distribution of medical therapy, admissions and discharges, completion of medical records, orders to the pharmacy, and printing tests from the corporate management systems Hopera and Concerto. Her supervisor confirms that she has never cared for Mr. (Y)."

With the aforementioned note dated July 6, 2023, the Company also attached a document titled "Delegation by the wife of the complainant," which, however, does not contain a delegation act for the withdrawal of the complainant's report (as stated in the aforementioned notification of violation), but only a statement from Mrs. (X), the complainant's wife, asking a colleague to print her husband's report ("I (X) ask my colleague in my presence to print the report of my husband (Y) dated 31/01/22").

In relation to the findings of the aforementioned investigative activity, the Office, with a note dated July 21, 2023 (prot. n. 111862), notified the territorial social health company of northern Milan, pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation, inviting the aforementioned holder to submit defensive writings or documents to the Authority or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981).

In particular, in the aforementioned note, the Office highlighted that the configuration of the health dossier carried out by the aforementioned Company was done in violation of the basic principles of processing as per Articles 5, paragraph 1, letters a) and f), 9, 25, and 32 of the Regulation. The violation of the aforementioned provisions makes the administrative sanction provided for in Article 83, paragraph 4, letter a) and paragraph 5, letter a) of the Regulation applicable.

With a note dated July 31, 2023, the Company sent the defensive writings, reiterating what had already been represented in the documents and highlighting, in particular, that:

"The nature of the violation is to be identified in a loss of confidentiality of the personal data of the interested party, as unauthorized third parties had access to it. (...) The violation is confined to this event and has not had further effects";

"Access to such information remained restricted to the two subjects mentioned above, one of whom, in the role he played at that time, was and is still bound by professional secrecy";

"The violation, in the opinion of ASST, denotes a negligent character, as the operator who printed the report for Mr. (Y)'s wife did so following a specific request from her and was led to believe that such a request was plausible following the delivery of a document in which this request was put in writing (not comparable to a delegation due to the lack of more elements), contravening company instructions (which should have led her not to print the document and to verify the accuracy of the document presented to her by Mrs. (X))";

"As for the organizational technical measures in place for the violation subject to this prospectus, the following is noted:

- regulations and corporate procedures have been adopted, disseminated, and made available on the corporate intranet. In particular, in this specific case: a Corporate IT Regulation, which contains precise information regarding access to applications, and instructions regarding the management of delegation acts (for which a specific model is in use in the Company). Furthermore, it is appropriate to note that these regulations, procedures, and internal instructions are under review, in order to make the internal

rules regarding the management and protection of personal data even clearer and more stringent;
- the corporate profile system is under review and integration, also due to the upcoming activation of the CCE system;

- access controls to corporate profiles have been carried out, which led to the elimination of non-operational profiles or those that had not connected to the system for some time;

- training courses on privacy are active."

2. Outcome of the investigative activity.

2.1. Legal framework of reference.

Preliminarily, it is represented that the processing of personal data must occur in compliance with the applicable regulations on personal data protection and, in particular, with the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 (hereinafter, the "Regulation") and Legislative Decree No. 196 of June 30, 2003 (Code regarding the protection of personal data – hereinafter, the "Code").

With particular reference to the matter at hand, it is emphasized that personal data must be "processed lawfully, fairly, and transparently" (principle of "lawfulness, fairness, and transparency" and "in a manner that ensures an adequate level of security (...), including protection against unauthorized or unlawful processing" (principle of "integrity and confidentiality") (Article 5, paragraph 1, letters a) and f) of the Regulation).

The Regulation further provides that the data controller must implement "appropriate technical and organizational measures to ensure a level of security appropriate to the risk," taking into account, among other things, "the nature, scope, context, and purposes of the processing, as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons" (Article 32 of the Regulation).

Taking into account, among other things, the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons arising from the processing, both at the time of determining the means of processing and at the time of the processing itself, the data controller must then implement appropriate technical and organizational measures aimed at effectively applying the principles of data protection, such as minimization, and ensuring that, by default, only personal data necessary for each specific purpose of the processing are processed (Article 25 of the Regulation).

With reference to the processing activities subject to the aforementioned complaint, the Authority has adopted the "Guidelines on Health Dossier - June 4, 2015" (Provision of June 4, 2015, published in G.U. 164 of July 17, 2015, available at [www.gdpd.it doc web no. 4084632](http://www.gdpd.it/doc/web/no.4084632)), in which a first framework of safeguards has been identified, in order to outline specific guarantees and responsibilities, as well as necessary and appropriate measures and precautions to ensure the protection of citizens concerning the processing of health data relating to them, which, like other provisions of the Authority, continue to apply even after the full implementation of the Regulation, as they are compatible with it (Article 22, paragraph 4, Legislative Decree No. 101/2018).

In the aforementioned 2015 guidelines, the Authority specified that the health dossier, constituting the set of personal data generated by current and past clinical events concerning the data subject, represents a specific and additional processing of personal data compared to that carried out by the healthcare professional with the information obtained during the care of the individual clinical event; as such, it is configured as an optional processing.

The data subject must indeed be allowed to choose, freely, whether the clinical information concerning them is processed in a health dossier or not, also guaranteeing them the possibility that the health data remains available only to the healthcare professional who drafted it, without its necessary inclusion in such a tool. This means that if the data subject does not express their consent to the processing of personal data through the health dossier, the professional who takes care of them will only have access to the information provided at that moment by the data subject (e.g., collection of the medical history, information related to the examination of the diagnostic documentation produced) and those

related to previous services provided by the same professional. Similarly, in such circumstances, the healthcare personnel of the ward/clinic will only have access to the information related to the episode for which the data subject approached that facility and to other information related to any healthcare services provided in the past to that subject by that ward/clinic (so-called access to departmental vertical applications).

In the aforementioned Guidelines, the Authority, in order to prevent the risk of access to the information processed through the health dossier by unauthorized persons or communication to third parties of health data by authorized persons, specifically requested the data controller to pay particular attention in identifying authorization profiles and in training authorized personnel, with access to the dossier being limited to only the healthcare personnel involved in the patient's care process and adopting technical authentication methods for the dossier that reflect the access cases specific to each healthcare facility. To this end, in the aforementioned Guidelines, the Authority indicated to the data controllers to monitor the cases in which the relevant healthcare personnel may need to consult the health dossier for the purpose of caring for the data subject and, based on this assessment, to identify the different authorization profiles for access.

It is also noted that in the aforementioned Guidelines, the Authority considered that "the data controller must implement systems for controlling access to the database and for detecting any anomalies that may constitute unlawful processing, through the use of anomaly indicators (so-called alerts) useful for guiding subsequent audit interventions. The controller must therefore foresee the activation of specific alerts that identify anomalous or risky behaviors related to the operations performed." of care provided, is involved in the treatment of the patient.

2.2 Legal Basis for Data Processing

The legal basis for the processing of personal data in the context of the aforementioned health emergency must be grounded in the applicable regulations on data protection, particularly the principles and limits applicable to processing as outlined in Article 5 of the Regulation. This includes ensuring that data is processed lawfully, fairly, and transparently in relation to the data subject ("lawfulness, fairness, and transparency"), collected for specified, explicit, and legitimate purposes ("purpose limitation"), and is adequate, relevant, and limited to what is necessary in relation to the purposes for which it is processed (data minimization principle).

In this regard, it should be noted that the Authority has repeatedly emphasized the need to evaluate the applicability of the provisions of the aforementioned Article 17-bis of Decree Law No. 18 of 2020 on a case-by-case basis, drawing the attention of data controllers operating in the health sector to the fact that not all processing and communication of health data can be attributed to this provision (see, among many, the note of June 9, 2020, web doc. No. 9429175).

With specific reference to the case at hand, it is also important to highlight what the Authority noted in the decision of November 10, 2022, adopted against a healthcare company that, during the health emergency period, had removed the measures put in place to protect the data of patients present in the company's health dossier (web doc. No. 9819792 - decision confirmed on the merits by the Civil Court of Aosta No. 144/2023).

2.1 Scope of Processing and Nature of Data Processed

In light of what has emerged from the investigative documents, the Company configured the health dossier in the context of the Covid-19 emergency in ways, still partially in effect, that allowed healthcare personnel (doctors, nurses, and healthcare assistants) to access this informational tool related to any patient present in the company's wards or in the emergency room.

It is also noted that, although the aforementioned corporate choice was made in relation to the Covid-19 emergency, the removal of the aforementioned filters did not only concern patients affected by this pathology but all those pertaining to the Company and was not limited to healthcare services provided during the emergency but extended to all those provided by the Company from March 2020 to the present, thus well beyond the end of the health emergency state (March 31, 2022).

In this context, it is noted that the choice made by the Company effectively allowed a healthcare assistant to access (and then communicate to third parties) information related to the healthcare services provided to the complainant, to which they would not have had access had the Company not modified the access conditions to the health dossier, as this operator was not involved in the care pathway of the data subject.

Therefore, it is observed that the choice made by the Company has effectively made the health dossiers of all its patients accessible regardless of the involvement of the healthcare operator in the care pathway and regardless of whether the healthcare service was actually provided to a Covid-19 patient, and without even providing for different levels of access to the dossier by the various authorized figures (healthcare assistants, doctors, nurses, emergency room personnel).

From this, it is evident that the Company did not adopt, as required by the aforementioned Guidelines of the Authority and the principles of personal data protection mentioned above (also referenced in the emergency provisions), measures that limit access to the dossier to only the healthcare personnel who are treating the data subject at the time of access. Access to the dossier must, in fact, be limited to only those healthcare personnel who are likely to intervene over time in the patient's care process, or who, based on the services provided, are involved in the treatment of the patient.

****3. Conclusions.****

In light of the evaluations mentioned above, considering the statements made by the data controller during the investigation – and given that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor" – it is represented that the elements provided by the data controller in the defensive memoranda related to the aforementioned proceedings do not allow for overcoming the observations notified by the Office with the acts initiating the proceedings for the adoption of corrective and sanctioning measures, nor do any of the cases provided for in Article 11 of the Guarantor Regulation no. 1/2019 apply.

For these reasons, the illegality of the processing of personal data carried out by the territorial social health company of North Milan is noted with reference to the procedure initiated following the complaint and the notification of violation, in the terms outlined in the reasoning, in particular, for having processed personal data in violation of Articles 5, paragraph 1, letters a) and f), 9, 25, and 32 of the Regulation.

In this context, considering that according to what has been stated in the documents by the Company, the measures adopted in March 2020 that allowed "access to the data of all departments of the hospital and the emergency room without specific limitations" are still provided for nurses and hospital doctors, it is deemed necessary to order the aforementioned Company, pursuant to Article 58, paragraph 2, letter d), of the Regulation.

Regulation, the following corrective measures to be adopted within 90 days from the adoption of this provision:

1. Limit access to the corporate health dossier to only healthcare personnel who are likely to intervene over time in the patient's care process, or who, based on the services provided and the clinical pathways activated, can actually be involved in the patient's care pathway, without prejudice to the possibility for the same to access health dossiers for which access has not been enabled by default in relation to specific events (including emergencies) declared by the same healthcare professional at the time of access;
2. Adopt a system for detecting any anomalies that may constitute unlawful processing, or the use of anomaly indicators (so-called alerts) aimed at identifying abnormal or risky behaviors related to the operations performed by authorized processing subjects (e.g., number of accesses performed, type or time frame of the same), useful for guiding subsequent audit interventions.
3. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The violation of Articles 5, paragraph 2, letters a) and f), 9, 25, and 32 of the Regulation, caused by the conduct of the Territorial Social Health Company of North Milan, is subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraphs 3, 4, and 5, of the Regulation. It should be noted that the Guarantor, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to the [other] corrective measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case" and, in this context, "the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Guarantor Regulation No. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided in Article 85, paragraph 2, of the Regulation in relation to which it is observed for both proceedings that:

- The Authority became aware of the event following the notification of the violation made by the data controller and, subsequently, through the complaint of the interested party (Article 83, paragraph 2, letter h) of the Regulation);
- The unlawful accesses concerned the health dossier of a patient by a healthcare professional who was not involved in the patient's care process (Article 83, paragraph 2, letters a) and b) of the Regulation);
- Access to the health dossier of the complainant was possible because the Company modified the configurations provided for access to patient dossiers during the Covid-19 emergency (Article 83, paragraph 2, letters a) and d) of the Regulation);
- The Company consciously chose to proceed with the modification of the settings for access to all corporate health dossiers of the entire assisted population, determining the possibility that the dossier could be consulted, without even different depths of access, by all corporate healthcare operators regardless of their involvement in the care pathway of the interested party (Article 83, paragraph 2, letters b) and d) of the Regulation);
- The aforementioned corporate choice, although made in relation to the Covid-19 emergency, did not concern only patients affected by that pathology but all those pertaining to the Company and its branches and was not limited to only the healthcare services provided in emergencies but to all those provided by the Company from March 2020 to the present and therefore well beyond the period of health emergency that ended on March 3, 2022 (Article 83, paragraph 2, letters a), b), c), and d) of the Regulation);
- In derogating from the limitations related to access to the health dossier dictated by the application of the regulation on personal data protection, the Company did not adopt a system for detecting any anomalies that may constitute unlawful processing, or the use of anomaly indicators (so-called alerts) aimed at identifying abnormal or risky behaviors related to the operations performed by authorized processing subjects (e.g., number of accesses performed, type or time frame of the same), useful for guiding subsequent audit interventions, in violation of the principles of integrity and confidentiality of personal data (Article 83, paragraph 2, letter d) of the Regulation);
- The Company has initiated, but not yet concluded, the "review and integration phase" of the "corporate profile system" for access to the dossier after the modifications introduced in March 2020 during the Covid-19 health emergency (Article 83, paragraph 2, letters a) and c) of the Regulation);
- The Company has been the recipient of a sanctioning provision from the Authority concerning violations relevant to the one under examination (provision of January 27, 2022, No. 34) (Article 83, paragraph 2, letter e) of the Regulation).

In light of the aforementioned elements, evaluated in their

In summary, it is deemed appropriate to determine the amount of the monetary sanction provided for by Article 83, paragraph 5, letter a) of the Regulation, for the violation of Articles 5, paragraph 2, letters a) and f), 9, 25, and 32 in the amount of €40,000 (forty thousand) for the procedure initiated following

the complaint as an administrative monetary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

It is also considered that the accessory sanction of publication on the Garante's website of this provision should be applied, as provided for by Article 166, paragraph 7 of the Code and Article 16 of the Garante's Regulation No. 1/2019, also in consideration of the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions set forth in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Garante, are met.

ALL OF THE ABOVE CONSIDERED, THE GARANTE

declares the unlawfulness of the processing of personal data carried out, in both the described proceedings, by the Territorial Social Health Company of North Milan, for the violation of Articles 5, paragraph 1, letters a) and f), 9, 25, and 32 of the Regulation as specified in the reasoning.

ORDERS

pursuant to Article 58, paragraph 2, letter d), of the Regulation, the Territorial Social Health Company of North Milan, within 90 days from the notification of this provision, to:

- limit access to the corporate health dossier to only healthcare personnel who can reasonably intervene over time in the patient's care process, or who, based on the services provided and the clinical pathways activated, can actually be involved in the patient's care pathway, without prejudice to the possibility for the same to access health dossiers for which access has not been enabled by default in the event of specific events (including emergencies) declared by the same healthcare professional at the time of access;
- adopt a system for detecting any anomalies that may constitute unlawful processing, or the use of anomaly indicators (so-called alerts) aimed at identifying anomalous or risky behaviors related to the operations performed by the subjects authorized to process (e.g., number of accesses performed, type or time frame of the same), useful for guiding subsequent audit interventions.

In this regard, the Company is requested to communicate what initiatives have been undertaken to implement the above orders with this provision and to provide adequately documented feedback, pursuant to Article 157 of the Code, within 20 days from the expiration of the above-mentioned deadline; any failure to respond may result in the application of the administrative monetary sanction provided for by Article 83, paragraph 5, of the Regulation.

ORDERS

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, the Territorial Social Health Company of North Milan, Tax Code 09320420962, to pay the sum of €40,000 (forty thousand) as an administrative monetary sanction for the aforementioned violations according to the methods indicated in the annex, within 30 days from the notification in reasoning; it is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by paying, within 30 days, an amount equal to half of the imposed sanctions.

ORDERS

the aforementioned Company, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sums of €40,000 (forty thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the subsequent executive acts in accordance with Article 27 of Law No. 689/1981.

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Garante's website and considers that the conditions set forth in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Garante, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree

No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, December 7, 2023

THE PRESIDENT

Stanzione

THE REPORTER

Cerrina Feroni

THE SECRETARY GENERAL

Mattei